PLANTILLA P47 · EVALUACIÓN DE IMPACTO EN PROTECCIÓN DE DATOS

Evaluación de impacto en protección de datos

Documenta la evaluación de impacto en protección de datos (EIPD) de un tratamiento que incorpora IA: qué se trata y para qué, si es necesario y proporcionado, qué riesgos crea para las personas y con qué medidas se reducen antes de empezar.

Fernando García Varela Versión 0.1 (borrador de trabajo) 19-09-2026 Borrador para revisión

EN ESTE DOCUMENTO

01 Instrucciones de uso

02 Identificación

03 Motivo de la evaluación

04 Descripción sistemática del tratamiento

05 Necesidad y proporcionalidad

06 Evaluación de los riesgos para los derechos y libertades

07 Medidas previstas

08 Consulta al delegado de protección de datos

09 Conclusión y consulta previa

10 Relación con otras evaluaciones

11 Revisión

12 Criterios de calidad

13 Aprobación y verificación

14 Control de versiones

> *Esta plantilla no constituye asesoramiento jurídico.* Referencias consultadas en septiembre de 2026; verifíquese su vigencia (documento 34 §6).

Aviso legal y exención de responsabilidad. SEVEN-G es un marco metodológico de referencia que se ofrece «tal cual» y con fines exclusivamente informativos. No constituye asesoramiento jurídico, regulatorio, financiero ni profesional, ni garantiza el cumplimiento de ninguna norma. Las referencias a regulación general (como el Reglamento Europeo de IA, el RGPD, DORA o NIS2), a normas técnicas y a regulación específica de cada sector o jurisdicción pueden ser incompletas, no aplicar a un caso concreto o quedar desactualizadas por cambios normativos, interpretaciones o criterios de las autoridades posteriores a su fecha de consulta. **Cada organización que use SEVEN-G es la única responsable de identificar la normativa que le aplica, verificar su vigencia y certificar su propio cumplimiento regulatorio**, con el asesoramiento cualificado que corresponda. Esta metodología es una ayuda genérica y gratuita, compartida con la comunidad para que nadie tenga que empezar desde cero; cada persona u organización puede y debe adaptarla a su propio uso. No debe entenderse que sus partes jurídicamente sensibles hayan sido revisadas por una asesoría jurídica: esas revisiones, para cada empresa o sector, son responsabilidad última de la empresa, el consultor o la organización que la use. Aunque se procura mantenerla al día, alguna norma puede haber cambiado sin que se recoja aquí. En la máxima medida permitida por la ley, el autor no asume responsabilidad alguna por los efectos de su aplicación en ninguna organización ni por su aplicabilidad completa. La metodología no otorga certificación de ningún tipo. El autor no asume responsabilidad alguna por el uso que se haga de este contenido ni por las decisiones que se adopten con él. Los datos, cifras, compañías y casos de los ejemplos son ficticios o ilustrativos.

Por qué importa. Cuando es obligatoria, la EIPD debe existir antes de iniciar el tratamiento (RGPD, artículo 35) y es condición de G3 y G4 en SEVEN-G. Sin ella, un sistema de IA puede llegar a producción tratando datos sin base jurídica clara, con inferencias o decisiones automatizadas no previstas y sin medidas proporcionadas; el resultado es un riesgo regulatorio y reputacional que ya no se corrige en el diseño, sino con la suspensión del sistema. Esta plantilla convierte la conclusión de P11 §9.1 («requerida») en una evaluación completa y verificable, integrada en el registro de riesgos (P12).

01

Instrucciones de uso

Aspecto	Indicación
Cuándo se usa	Se abre cuando P11 §9.1 concluye que la evaluación es **Requerida** (o **Recomendada** y la compañía decide hacerla). Se elabora en la fase 3, antes de G3; se actualiza en la fase 4 con el diseño (G4) y se revisa en cada R6 y ante cualquier cambio de la sección 11. Siempre antes de iniciar el tratamiento.
Quién la rellena	El responsable del tratamiento, coordinado por el responsable de riesgos de IA (32 §6.1). El responsable de producto de IA y el responsable técnico de IA aportan la descripción del tratamiento y las medidas.
Quién la verifica	Lite: oficina de IA o auditor de IA. Enterprise: auditor de IA. El delegado de protección de datos asesora y supervisa, pero no figura como autor (documento 30; RGPD, artículo 39).
Quién decide o aprueba	El responsable del tratamiento, en el órgano que corresponda al riesgo residual (sección 9 y P12 §6). La consulta previa a la autoridad de control la decide el mismo órgano cuando procede.
Gate o momento	Viabilidad (existe o está iniciada con cierre antes de G4, G3.09); G4 · Diseño (completada y medidas en el diseño, G4.13); R6 (vigente, R6.08). (G3)
Herramienta	T07 · Clasificador regulatorio (estado, fecha y enlace de la evaluación en la ficha del sistema, 32 §3.5).
Documento de referencia	32 §6.1 (cuándo y quién), 34 §6.1 y §6.2 (artículos y guías), documento 33 (escalas de riesgo), documento 51 (datos).
Lite frente a Enterprise	Lite puede omitir los campos marcados **(Enterprise)**. Si la EIPD es obligatoria, su contenido mínimo es el mismo en ambas.

Reglas de cumplimentación:

- **Una evaluación por tratamiento.** Si varios sistemas de IA (SIA-AAAA-NNN) comparten tratamiento, se evalúan juntos; si un sistema tiene tratamientos distintos (por ejemplo, entrenamiento y uso), se describen por separado en la sección 4.
- La plantilla puede sustituirse por la metodología propia de la compañía si cubre todos los bloques; en ese caso se enlaza y se completan solo las secciones 2, 9 y 13.
- Los riesgos se valoran con la **escala común** (especificación común §5.1, documento 33) y los de nivel Medio o superior se trasladan a **P12** con su código IA-AAAA-NNN · Rnn.
- Guías de apoyo: Directrices sobre la evaluación de impacto relativa a la protección de datos (WP248 rev.01) del CEPD, las listas de tratamientos que requieren evaluación publicadas por la AEPD y las Guías de la AEPD sobre tratamientos que incorporan IA y auditoría de esos tratamientos.

02

Identificación

Campo	Contenido	Guía
Código del caso de uso		IA-AAAA-NNN.
Sistemas de IA incluidos		SIA-AAAA-NNN de P05 (T02).
Nombre del tratamiento		Como figura, o figurará, en el registro de actividades de tratamiento (RGPD, artículo 30).
Responsable del tratamiento		Sociedad del grupo que decide los fines y medios.
Encargados del tratamiento		Proveedores que tratan datos por cuenta de la compañía (P14).
Referencia a P11		Versión y fecha de la clasificación que concluyó que la EIPD es necesaria.
Delegado de protección de datos		Nombre o función.
Versión del documento		
Fecha		DD-MM-AAAA.
Estado		Borrador · En consulta al delegado · Presentada para verificación · Aprobada · En consulta previa · Sustituida.

03

Motivo de la evaluación

Copie las respuestas de P11 §9.1 y añada la justificación. Basta un «Sí» para que la evaluación sea obligatoria.

Criterio	Sí · No	Justificación
Evaluación sistemática y exhaustiva de aspectos personales basada en tratamiento automatizado, incluida la elaboración de perfiles, que sirve de base para decisiones con efectos jurídicos o significativos (artículo 35.3.a)		
Tratamiento a gran escala de categorías especiales de datos o de datos relativos a condenas e infracciones penales (artículo 35.3.b)		
Observación sistemática a gran escala de una zona de acceso público (artículo 35.3.c)		
Figura en las listas de tratamientos que requieren evaluación de la autoridad de control competente		Indicar el tipo de tratamiento de la lista.
Otros indicios de alto riesgo según WP248 rev.01 (por ejemplo, uso innovador de tecnología, combinación de conjuntos de datos, personas vulnerables)		
Decisiones basadas únicamente en tratamiento automatizado con efectos jurídicos o significativos (artículo 22)		Si es «Sí», la sección 5 debe acreditar la excepción aplicable y sus garantías.

04

Descripción sistemática del tratamiento

4.1 Finalidades y contexto

Campo	Contenido	Guía
Finalidad o finalidades		Concretas y explícitas. Coherentes con la finalidad prevista de P05 y P11.
Proceso de negocio en que se inserta		En lenguaje comprensible (P31).

Campo	Contenido	Guía
Papel de la IA en el tratamiento		Qué hace el sistema con los datos: clasificar, puntuar, generar, recomendar, decidir. Nivel de autonomía A0–A3.
¿Hay decisiones sobre personas?		Qué decisiones, quién las toma y con qué supervisión (P17).
Interés o beneficio perseguido		Para la compañía, para los interesados o para terceros.

4.2 Datos e interesados

Campo	Contenido	Guía
Categorías de interesados		Clientes, empleados, candidatos, ciudadanos, menores u otros colectivos vulnerables.
Número aproximado de interesados		Orden de magnitud y ámbito geográfico.
Categorías de datos		Identificativos, de contacto, económicos, de comportamiento, contenido libre (texto, voz, imagen).
Categorías especiales o datos penales		Cuáles y por qué son necesarios.
Datos inferidos o generados por el sistema		Puntuaciones, perfiles, resúmenes, categorías deducidas. También son datos personales.
Fuentes		Del interesado, de sistemas internos, de terceros, de fuentes públicas.

4.3 Ciclo de vida de los datos

Etapa	Qué datos	Dónde y quién los trata	Conservación	Guía
Entrenamiento o ajuste				Solo si la compañía entrena o ajusta un modelo (P16).
Prueba y validación				Datos de prueba, anonimizados o seudonimizados cuando sea posible.
Uso en producción (entradas y resultados)				Incluye instrucciones, contexto recuperado y registros.

Etapa	Qué datos	Dónde y quién los trata	Conservación	Guía
Registros y trazabilidad				Coherente con los plazos de conservación de registros (32 §3.5).
Retirada				Conservación, borrado o transferencia (P30).

4.4 Tecnología y terceros

Campo	Contenido	Guía
Modelo o modelos de IA		Propio, de terceros por API, ajustado. Proveedor y versión (P15, P16).
Uso de los datos por el proveedor para entrenamiento		No · Sí · Sin dato (32 §3.6).
Localización del tratamiento		Espacio Económico Europeo · Fuera con garantías adecuadas · Sin dato.
Información del proveedor del sistema utilizada (Enterprise)		Si la compañía es responsable del despliegue de un sistema de alto riesgo, la información del artículo 13 del Reglamento de IA que se ha usado (artículo 26.9).

05

Necesidad y proporcionalidad

Aspecto	Contenido	Guía
Base jurídica (artículo 6)		Una por finalidad. Confirmada por la función de protección de datos (G3.03).
Condición para categorías especiales (artículo 9)		Incluido el tratamiento para detectar y corregir sesgos, con sus condiciones (34 §3.2, documento 51).
Limitación de la finalidad		Cómo se impide el uso para otras finalidades.
Minimización		Qué datos se han descartado y por qué los restantes son necesarios.
Exactitud		Cómo se evita que datos o resultados inexactos afecten a las personas.

Aspecto	Contenido	Guía
Limitación del plazo de conservación		Plazos por etapa (sección 4.3).
¿Es necesaria la IA para esta finalidad?		Alternativas menos intrusivas consideradas, incluida la alternativa sin IA (P06).
Información a los interesados (artículos 13 y 14)		Incluida la existencia de decisiones automatizadas y la información significativa sobre la lógica aplicada (P49).
Ejercicio de derechos		Acceso (incluido el artículo 15.1.h), rectificación, supresión, oposición; cómo se atienden cuando los datos están en un modelo o en registros.
Garantías de las decisiones automatizadas (artículo 22)		Excepción aplicable; intervención humana, expresar el punto de vista e impugnar (P17 §8).
Encargados y contratos		Contrato de encargo y condiciones del proveedor (P14).
Transferencias internacionales		Garantías aplicables.

06

Evaluación de los riesgos para los derechos y libertades

Valore cada riesgo desde el punto de vista de las personas, no de la compañía. El eje de impacto dominante será normalmente «Personas y derechos» (P12 §3.2). **Nivel = Probabilidad × Impacto**: Bajo 1–4 · Medio 5–9 · Alto 10–15 · Crítico 16–25.

Riesgos que conviene revisar en tratamientos con IA: acceso o revelación indebidos (incluida la fuga de datos por inyección de instrucciones o por memorización del modelo); inferencias no esperadas por el interesado; resultados sesgados o discriminatorios; decisiones inexactas con efecto sobre la persona; reidentificación de datos seudonimizados; pérdida de control del interesado sobre sus datos; imposibilidad práctica de ejercer derechos; reutilización para otras finalidades; observación o seguimiento excesivo.

Nº	Riesgo para las personas (causa, evento y consecuencia)	Interesados afectados	P inh.	I inh.	Nivel inherente	Medidas (sección 7)	P res.	I res.	Nivel residual	Código en P12
E01			1–5	1–5	Bajo · Medio · Alto · Crítico	M..				IA-AAAA-NNN · Rnn
E02										
E03										
***(ejemplo ilustrativo)* E01**	Un asistente que clasifica reclamaciones de clientes infiere datos de salud a partir del texto libre y los guarda en los registros, sin base jurídica para ese tratamiento.	Clientes que reclaman	4	4	16 Crítico	M01, M02	2	3	6 Medio	IA-2026-014 · R03

07

Medidas previstas

Nº	Medida	Riesgos que trata	Tipo	Dónde se implanta	Responsable	Estado
Navegar por el sitio (M01)		E..	Técnica · Organizativa · Contractual	P15 · P16 · P17 · P18 · P24 · P49 · P14		Prevista · Implantada · Verificada
Qué es SEVEN-G y qué problema resuelve (M02)						

Nº	Medida	Riesgos que trata	Tipo	Dónde se implanta	Responsable	Estado
(ejemplo ilustrativo) **M01**	Filtro de detección y enmascaramiento de datos de salud antes de guardar el registro; conservación de registros limitada a 6 meses.	E01	Técnica	P16, P24	Responsable técnico de IA	Implantada
(ejemplo ilustrativo) **M02**	Aviso en el formulario de reclamación de que no deben incluirse datos de salud salvo que sean necesarios para la reclamación.	E01	Organizativa	P49	Responsable de producto de IA	Prevista

Una medida solo reduce el riesgo residual si existe y funciona (P12). Las medidas «Previstas» deben estar implantadas antes de iniciar el tratamiento, o el riesgo se valora sin ellas.

08

Consulta al delegado de protección de datos

Campo	Contenido	Guía
Fecha de la consulta		Antes de la aprobación.
Opinión del delegado		Resumen o referencia al informe.
Recomendaciones		Una por fila si son varias.
¿Se siguen las recomendaciones?		Sí · Parcialmente · No. Si no se siguen, motivo y quién lo decide.
Opinión de los interesados o de sus representantes (Enterprise)		Cuando proceda y sea posible; si no se recaba, motivo.

09

Conclusión y consulta previa

Campo	Contenido	Guía
Nivel residual más alto		De la sección 6.
Conclusión		El tratamiento puede iniciarse · Puede iniciarse con condiciones · No puede iniciarse.
Condiciones		Medidas que deben estar verificadas y fecha.
¿Procede consulta previa a la autoridad de control (artículo 36)?		Sí, si el riesgo residual sigue siendo alto pese a las medidas. En SEVEN-G, además, riesgo residual Alto o Crítico con su nivel de aceptación (32 §6.1; documento 30 §7.2).
Autoridad de control competente		En España, la Agencia Española de Protección de Datos .
Fecha de la consulta previa y respuesta		El tratamiento no se inicia hasta disponer de la respuesta o del plazo aplicable.
Aceptación del riesgo residual		Órgano según P12 §6. Un residual Crítico sin aprobación del consejo o de su comisión delegada bloquea G3 y G5.

10

Relación con otras evaluaciones

Evaluación	¿Aplica?	Cómo se coordina
Evaluación de impacto en derechos fundamentales (P48)	Sí · No	La complementa sin duplicarla (artículo 27.4 del Reglamento de IA): se reutilizan la descripción del tratamiento y los riesgos para la protección de datos.
Registro de riesgos del caso de uso (P12)	Sí	Los riesgos E.. de nivel Medio o superior figuran en P12.
Diseño de seguridad (P18)		Medidas técnicas de seguridad de los datos.
Evaluaciones sectoriales o de terceros (Enterprise)		DORA , NIS2 u otras (P11 §9.3).

11

Revisión

La evaluación se revisa en cada R6 y, además, siempre que cambie alguno de estos elementos: finalidad, categorías de datos o de interesados, fuentes, modelo o proveedor, nivel de autonomía, alcance de las decisiones sobre personas, localización del tratamiento o criterio de la autoridad. El cambio se registra en P27.

Fecha	Motivo	Cambios en la evaluación	Nivel residual resultante	Revisado por
	Cambio · Incidente · Criterio de la autoridad (R6)			

12

Criterios de calidad

Los criterios formales están en el documento 21 (G3.03, G3.09, G4.13 y R6.08).

#	Comprobación	Estado
1	El motivo de la evaluación coincide con P11 §9.1 y está justificado.	Cumple · No cumple · No aplica · Pendiente
2	La descripción cubre finalidades, datos, interesados, ciclo de vida de los datos, tecnología y terceros.	
3	Cada finalidad tiene base jurídica confirmada por la función de protección de datos (G3.03).	
4	Se ha analizado la necesidad de la IA y la alternativa menos intrusiva.	
5	Los riesgos se valoran desde las personas, con la escala común, inherente y residual, y los de nivel Medio o superior están en P12.	
6	Cada riesgo tiene medidas con responsable; las medidas que reducen el residual están implantadas.	
7	Consta la opinión del delegado de protección de datos y qué se hizo con ella.	
8	Se ha decidido de forma motivada sobre la consulta previa.	

#	Comprobación	Estado
9	La evaluación es anterior al inicio del tratamiento y sus medidas están incorporadas al diseño (G4.13).	
Mapa de esferas y niveles de ambición (10)	Está vigente en la última R6 (R6.08).	

13

Aprobación y verificación

Función	Rol en SEVEN-G	Nombre y cargo	Fecha	Firma o referencia
Coordina y elabora	Responsable de riesgos de IA, por cuenta del responsable del tratamiento			
Aporta descripción y medidas	Responsable de producto de IA y responsable técnico de IA			
Asesora y supervisa	Delegado de protección de datos			
Verifica	Oficina de IA o auditor de IA (Lite) · Auditor de IA (Enterprise)			
Aprueba y acepta el residual	Órgano según P12 §6			
☐ **Declaración: «La organización confirma que esta evaluación se ha realizado con asesoramiento cualificado y asume su responsabilidad; SEVEN-G es solo una referencia metodológica.»**	Mismo órgano que aprueba			

Separación de funciones: el delegado de protección de datos no es autor de la evaluación ni la aprueba; quien la elabora no la verifica.

14

Control de versiones

Documento cumplimentado

Versión	Fecha	Autor	Cambios

Plantilla

Versión	Fecha	Cambios
0.1	19-09-2026	Primera versión. Desarrolla la evaluación que P11 §9.1 declara necesaria, con el contenido de 32 §6.1 y 34 §6.1, las escalas comunes de riesgo y el enlace con P12 y P48. Referencias consultadas en septiembre de 2026.

Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo, de 14 de diciembre de 2022, relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión (Directiva SRI 2 / NIS2) · https://eur-lex.europa.eu/eli/dir/2022/2555/oj/spa · Parlamento Europeo y Consejo de la UE · 14-12-2022

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos) · https://eur-lex.europa.eu/eli/reg/2016/679/oj/spa · Parlamento Europeo y Consejo de la UE · 27-04-2016

Reglamento (UE) 2022/2554 del Parlamento Europeo y del Consejo, de 14 de diciembre de 2022, sobre la resiliencia operativa digital del sector financiero (DORA) · https://eur-lex.europa.eu/eli/reg/2022/2554/oj/spa · Parlamento Europeo y Consejo de la UE · 14-12-2022

Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas en materia de inteligencia artificial (Reglamento de

Inteligencia Artificial) · https://eur-lex.europa.eu/eli/reg/2024/1689/oj/spa · Parlamento Europeo y Consejo de la UE · 13-06-2024

Agencia Española de Protección de Datos (AEPD) · https://www.aepd.es/ · Agencia Española de Protección de Datos

Comité Europeo de Protección de Datos (CEPD) · https://www.edpb.europa.eu/edpb_es · Comité Europeo de Protección de Datos (organismo de la UE creado por el art. 68 del RGPD)

Directrices sobre la evaluación de impacto relativa a la protección de datos (EIPD) y para determinar si el tratamiento «entraña probablemente un alto riesgo» a efectos del Reglamento 2016/679 (WP248 rev.01), del Grupo de Trabajo del Artículo 29, asumidas por el CEPD · https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/data-protection-impact-assessments-high-risk-processing_es · Grupo de Trabajo del Artículo 29; asumidas por el Comité Europeo de Protección de Datos (25-05-2018) · 04-10-2017

Guías de la AEPD sobre tratamientos que incorporan IA: «Adecuación al RGPD de tratamientos que incorporan Inteligencia Artificial. Una introducción» (febrero de 2020) y «Requisitos para Auditorías de Tratamientos que incluyan IA» (enero de 2021) · página «Innovación y Tecnología» que reúne ambas · https://www.aepd.es/areas-de-actuacion/innovacion-y-tecnologia · Agencia Española de Protección de Datos

Listas de tipos de tratamientos de datos que requieren evaluación de impacto relativa a la protección de datos (art. 35.4 RGPD) · https://www.aepd.es/documento/listas-dpia-es-35-4.pdf · Agencia Española de Protección de Datos · 06-05-2019